

NUNCHI · SECURITY REVIEW

Nunchi

Genesis Vaults Updates.

A security review of Genesis Vaults Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Nunchi	Genesis Vaults Updates	Guardian	October 27 – November 5, 2025	November 12, 2025

§ 00

Contents.

28 pages — overview, confidence ranking, scope, 18 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 16 findings	P. 09
	Remediation Review · 2 findings	P. 25
§ 05	Disclaimer	P. 27
§ 06	About Guardian	P. 28

§ 01

Overview.

Guardian reviewed Genesis Vaults Updates across 2 review rounds. The final report includes 2 High, 9 Medium, 5 Low, 2 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	Nunchi-trade/genesis-vaults
CLIENT	METHODOLOGY
Nunchi	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
Genesis Vaults Updates	417a877e2472
PREPARED BY	REMEDATION REVIEW COMMIT
Guardian	e03566d054e2
AUDIT WINDOW	
October 27 – November 5, 2025	
FINAL REPORT	
November 12, 2025	

1.1 Confidence Ranking

4 / 5

High Confidence

Guardian assigns a Confidence Ranking of 4 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	2	0	0	0	2
Medium	9	0	3	0	6
Low	5	0	2	0	3
Informational	2	0	1	0	1
All severities	18	0	6	0	12

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence ASSIGNED	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Genesis Vaults Updates in `Nunchi-trade/genesis-vaults`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
H-01	Invalid Redeem Handling	Logical Error	HIGH	RESOLVED	p. 9
H-02	LayerZero Read Messaging Channel DoS	DoS	HIGH	RESOLVED	p. 10
M-01	burnForMigration Avoids Withdrawal Delay	Gaming	MEDIUM	ACKNOWLEDGED	p. 11
M-02	Cooldown Withdrawal DoS	DoS	MEDIUM	RESOLVED	p. 12
M-03	Cooldown Bypass	Gaming	MEDIUM	RESOLVED	p. 13
M-04	AlreadyBurned Check Bypass	Validation	MEDIUM	ACKNOWLEDGED	p. 14
M-05	Cooldown Withdrawal DoS Via Transfer	DoS	MEDIUM	RESOLVED	p. 15
M-06	strategyInUse Not Reset During Migration	Validation	MEDIUM	RESOLVED	p. 16
M-07	Cooldown Bypass Via Internal Burn	Logical Error	MEDIUM	RESOLVED	p. 17
L-01	Users Can Deposit After Burning	Warning	LOW	ACKNOWLEDGED	p. 18
L-02	Incorrect getUserAccountSummary output	Rewards	LOW	RESOLVED	p. 19
L-03	Performance Fee Is Enforced	Rewards	LOW	RESOLVED	p. 20
L-04	Wrong Migration Delay	Configuration	LOW	ACKNOWLEDGED	p. 21
L-05	Minimum Withdraw Applies Before Penalty	Logical Error	LOW	RESOLVED	p. 22

Findings continued.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
I-01	Redundant Receiver Parameter	Superfluous Code	INFORMATIONAL	ACKNOWLEDGED	p. 23
I-02	Unused Code	Superfluous Code	INFORMATIONAL	RESOLVED	p. 24

REMEDIATION REVIEW

M-01	Withdraw DoS Bypass	Validation	MEDIUM	ACKNOWLEDGED	p. 25
M-02	getUserSharesForClaim Could Still Revert	DoS	MEDIUM	RESOLVED	p. 26

HIGH **H-01**

RESOLVED

Invalid Redeem Handling

CATEGORY	Logical Error
LOCATION	GenesisVaultSYToken.sol: 284
REVIEW	Main Review

— DESCRIPTION

VaultModule.withdraw returns the pre-penalty 'assets' value but transfers only the net assets after applying the global withdrawal penalty. GenesisVaultSYToken._redeem uses the returned value as the amount to forward to the receiver, leading it to attempt transferring more tokens than it actually received. This will either revert due to insufficient balance or, if the SY contract holds any underlying balance, overpay the user and drain those funds.

— RECOMMENDATION

Make the amounts consistent. Either (a) change VaultModule.withdraw to return the netAssets actually transferred to msg.sender, or (b) change GenesisVaultSYToken._redeem to derive the net amount by tracking the SY contract's asset balance delta (before and after withdraw) and transfer only that net amount. Also base the slippage check on the net amount.

— RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/21>

HIGH **H-02**

RESOLVED

LayerZero Read Messaging Channel DoS

CATEGORY	DoS
LOCATION	GenesisVaultLSYToken.sol
REVIEW	Main Review

DESCRIPTION

The `getUserSharesForClaim` function is intended to be invoked by LayerZero's `IzRead` function to distribute the state to other chains. It includes several revert cases if the `vaultId` is incorrect or the vault is not yet fully migrated.

However `IzRead` target functions should never revert, otherwise they would prevent DVNs from verifying the result and halt the read messaging channel, thus stopping the migration until it is manually unblocked, at which point it can be halted again.

RECOMMENDATION

Ensure the `getUserSharesForClaim` never reverts and instead returns an empty/sentinel value which can be ignored for invalid cases.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/21>

MEDIUM **M-01**

ACKNOWLEDGED

burnForMigration Avoids Withdrawal Delay

CATEGORY Gaming
LOCATION GenesisVaultSYToken.sol: 301
REVIEW Main Review

— DESCRIPTION

In the `burnForMigration` function there is no validation that the user has passed the withdrawal delay before burning their tokens for the migration.

Therefore the migration may offer a pathway for the user to exit their position in the VaultSYToken before the delay is up.

— RECOMMENDATION

Consider if the `withdrawalDelay` should be validated before a user is allowed to invoke the `burnForMigration` function.

— RESOLUTION

Status: Acknowledged.

MEDIUM **M-02**

RESOLVED

Cooldown Withdrawal DoS

CATEGORY DoS
LOCATION GenesisVaultSYToken.sol
REVIEW Main Review

DESCRIPTION

The `deposit` function allows the caller to provide an arbitrary receiver address and the receiver is the account which will have their withdrawal cooldown assigned, preventing them from withdrawing for the `withdrawalDelay` period.

Furthermore, there is no minimum deposit amount, which means that a malicious actor could prevent users from withdrawing their assets by continually depositing 1 wei of assets on behalf the user, specifying the victim user as the `receiver` and resetting their `lastDepositTime`.

RECOMMENDATION

Consider requiring that the receiver is the account invoking the deposit function, or that the caller is in a whitelisted group for the receiver so that this griefing cannot occur.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/21>

MEDIUM **M-03**

RESOLVED

Cooldown Bypass

CATEGORY Gaming
LOCATION GenesisVaultSYToken.sol
REVIEW Main Review

DESCRIPTION

The cooldown mechanism for withdrawals can be bypassed if a user specifies the `GenesisVaultSYToken` contract as the receiver and then invokes the `redeem` function with `burnFromInternalBalance` as `true`.

This way the `lastDepositTime` entry is set for the `GenesisVaultSYToken` contract but never read, since the `redeem` function relies on the entry for the `msg.sender`.

This allows users to cause a deposit on behalf of the `GenesisVaultSYToken` contract and withdrawal to arbitrary receiver within a single transaction, while bypassing the withdrawal cooldown which may be unexpected for the system.

RECOMMENDATION

Consider validating that the receiver is not `address(this)` in the `deposit` function to prevent users from circumventing the `withdrawalDelay` this way.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/21>

MEDIUM **M-04**

ACKNOWLEDGED

AlreadyBurned Check Bypass

CATEGORY Validation

LOCATION <https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/8800754ee52133d27339f0c42a66a2859490844/src/genesis/tokens/GenesisVaultSYToken.sol#L313-L316>

REVIEW Main Review

DESCRIPTION

The `AlreadyBurned` check in the `burnForMigration` function can be bypassed by transferring the tokens to another EOA.

RECOMMENDATION

Consider to prevent sending and receiving token if the user already burned or consider if this validation is necessary in general. Another solution could be to prevent transfers after the migration.

RESOLUTION

Status: Acknowledged.

MEDIUM **M-05**

RESOLVED

Cooldown Withdrawal DoS Via Transfer

CATEGORY	DoS
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/7b24690d37e90d069213d3866b0de146958e2bf2/src/genesis/tokens/GenesisVaultSYToken.sol#L349-L363
REVIEW	Main Review

DESCRIPTION

The `_beforeTokenTransfer` function of the `GenesisVaultSYToken` will update the recipient's `lastDepositTime` to the one of the sender if it's bigger than the current one.

This enables a withdrawal griefing DoS:

- Malicious actor deposits the minimum amount into the system and by doing so the attacker's `lastDepositTime` is set to now
- Another user tries to withdraw tokens
- The malicious actor front runs the call and transfers 1 wei to the user
- The victims `lastDepositTime` is updated and therefore the withdraw fails as the withdrawal delay has not passed yet.

RECOMMENDATION

Consider to create a whitelist mechanism to allow users to configure who can send them tokens. Or to add a minimum transfer amount to make this DoS attack too expensive to realistically take place.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

MEDIUM **M-06**

RESOLVED

strategyInUse Not Reset During Migration

CATEGORY Validation

LOCATION <https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/7b24690d37e90d069213d3866b0de146958e2bf2/src/genesis/modules/MigrationModule.sol#L102-L104>

REVIEW Main Review

— DESCRIPTION

If the given vault used a strategy it will be unset in the `migrateVault` flow. However the `strategyInUse` mapping is not set to false and therefore the strategy can never be used again and needs to be redeployed.

— RECOMMENDATION

Consider to set the `strategyInUse` mapping to false in that case.

— RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

MEDIUM **M-07**

RESOLVED

Cooldown Bypass Via Internal Burn

CATEGORY	Logical Error
LOCATION	GenesisVaultSYToken.sol
REVIEW	Main Review

— DESCRIPTION

In GenesisVaultSYToken, the redeem function enforces withdrawal delay using `lastDepositTime[msg.sender]` even when burning shares directly from the contract (`burnFromInternalBalance=true`). An attacker can transfer their shares to the Factory contract, and then immediately redeem from a fresh account to bypass the cooldown.

— RECOMMENDATION

When burning from internal balance, enforce cooldown based on the balance owner whose tokens are being burned or disallow `burnFromInternalBalance` path.

— RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

LOW **L-01**

ACKNOWLEDGED

Users Can Deposit After Burning

CATEGORY Warning
LOCATION GenesisVaultLSYToken.sol
REVIEW Main Review

DESCRIPTION

The `burnForMigration` function states that `Users must burn their full balance to track for cross-chain claims`, and the function does indeed burn the entire user balance of the user. However there is no validation that prevents the same user from depositing again through the deposit function.

This user will not be able to invoke the `burnForMigration` function again, however it may be unexpected for the migration that the user now has a balance in excess of what was burned previously.

RECOMMENDATION

Consider if this is expected for the migration and avoid this edge case in the migration logic. If it should be prevented, consider validating that the `burnedBalances` entry for the user is zero before allowing a deposit to occur.

RESOLUTION

Status: Acknowledged.

LOW **L-02**

RESOLVED

Incorrect `getUserAccountSummary` output

CATEGORY	Rewards
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/8800754ee52133d27339f0c42a66a2859490844/src/genesis/modules/VaultModule.sol#L161-L172
REVIEW	Main Review

DESCRIPTION

The `getUserAccountSummary` function calculates and returns the `earnedYield` of the user.

The calculation compares the deposited and withdrawn amount of the user and sums it up with the current worth of the users shares.

The comparison of the withdrawn and deposited amount takes into account the paid fees while the worth of the user's shares does not.

RECOMMENDATION

Consider to apply the withdraw penalty.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

LOW **L-03**

RESOLVED

Performance Fee Is Enforced

CATEGORY	Rewards
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/417a877e2472e126af998ec1518871f512b6e1b6/src/genesis/storage/Vault.sol#L492-L498
REVIEW	Main Review

DESCRIPTION

The `collectPerformanceFee` function handles the case that no performance fee is set: `if (recipient == address(0) || rate == 0 || yield == 0) { return (0, yield);}`

However the `harvestAndCompound` function which calls it early returns if no performance fee is configured: `if (vault.strategy == address(0) || !hasPerformanceFeeConfigured(vault)) { return (0, 0); }`

RECOMMENDATION

Consider to allow not configuring a performance and giving all yield to the users in that case.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

LOW **L-04**

ACKNOWLEDGED

Wrong Migration Delay

CATEGORY Configuration

LOCATION <https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/417a877e2472e126af998ec1518871f512b6e1b6/src/genesis/modules/MigrationModule.sol#L22-L27>

REVIEW Main Review

DESCRIPTION

The `MIN_MIGRATION_DELAY` is set to one day, while the documentation states out it is 3 days.

RECOMMENDATION

Consider to update the constant or the comment.

RESOLUTION

Status: Acknowledged.

LOW **L-05**

RESOLVED

Minimum Withdraw Applies Before Penalty

CATEGORY	Logical Error
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/417a877e2472e126af998ec1518871f512b6e1b6/src/genesis/modules/VaultModule.sol#L73
REVIEW	Main Review

DESCRIPTION

In VaultModule, withdraw function enforces `minWithdraw` on gross assets before applying the withdrawal penalty. If `grossAssets` is greater than or equal to `minWithdraw` but the penalty reduces `netAssets` below `minWithdraw`, the withdrawal still succeeds, allowing dust withdrawals contrary to intended behaviour.

RECOMMENDATION

Consider enforcing `minWithdraw` on the post penalty amount.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

INFORMATIONAL **I-01**

ACKNOWLEDGED

Redundant Receiver Parameter

CATEGORY	Superfluous Code
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/417a877e2472e126af998ec1518871f512b6e1b6/src/genesis/tokens/GenesisVaultSYToken.sol#L186-L188
REVIEW	Main Review

— DESCRIPTION

The `deposit` takes in a `receiver` parameter but reverts if it's not the `msg.sender`.

— RECOMMENDATION

Consider to use the `msg.sender` instead.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-02**

RESOLVED

Unused Code

CATEGORY	Superfluous Code
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

There is unused code in multiple places:

- The `VaultNotMigrated` error in `Errors.sol`
- The `IERC165` import in `ConfigurationModule.sol`

RECOMMENDATION

Consider to remove unused code.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/25>

MEDIUM **M-01**

ACKNOWLEDGED

Withdraw DoS Bypass

CATEGORY	Validation
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/e03566d054e26442e9ff324aff4cd34e186227bd/src/genesis/tokens/GenesisVaultSYToken.sol#L360-L365
REVIEW	Remediation Review

DESCRIPTION

The `lastDepositTime` of the SY token recipient is now only increased if the recipient currently does not own tokens.

This allows to bypass the withdraw delay by transferring to another EOA if the user has multiple accounts holding the SY tokens.

RECOMMENDATION

Consider to acknowledge this behavior or to create a whitelist mechanism to allow users to configure who can send them tokens and to revert the recent changes.

RESOLUTION

Status: Acknowledged.

MEDIUM **M-02**

RESOLVED

getUserSharesForClaim Could Still Revert

CATEGORY	DoS
LOCATION	https://github.com/GuardianOrg/genesis-vaults-team1-1761063695425/blob/e03566d054e26442e9ff324aff4cd34e186227bd/src/genesis/tokens/GenesisVaultSYToken.sol#L337-L350
REVIEW	Remediation Review

DESCRIPTION

The `getUserSharesForClaim` function is intended to be invoked by LayerZero's `IzRead` function to distribute the state to other chains and reverts if the `vaultId` is incorrect.

However `IzRead` target functions should never revert, otherwise they would prevent DVNs from verifying the result and halt the read messaging channel, thus stopping the migration until it is manually unblocked, at which point it can be halted again.

RECOMMENDATION

Ensure the `getUserSharesForClaim` never reverts and instead returns an empty/sentinel value which can be ignored for invalid cases.

RESOLUTION

Status: Resolved.

<https://github.com/Nunchi-trade/genesis-vaults/pull/28>

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.